



Schweizerische Eidgenossenschaft
Confédération suisse
Confederazione Svizzera
Confederaziun svizra

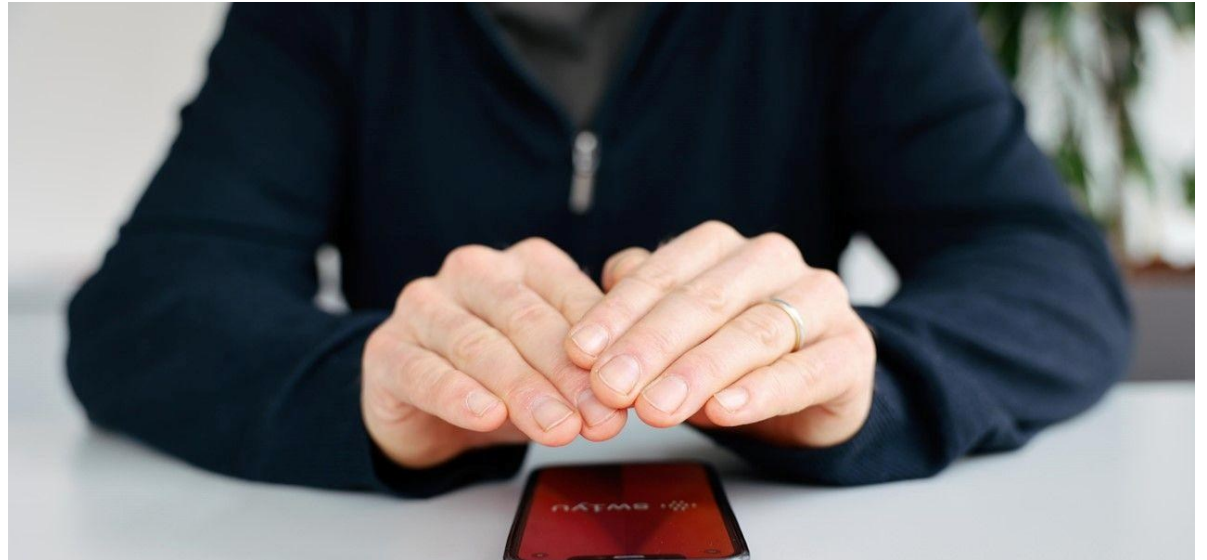
armasuisse
Science and technology

Frontdoors, Not Backdoors: Accountable Anonymity for National Digital Identity

Dr. Martin Burkhart
(CYD Campus)

Shailesh Mishra, Roxanne Chevalley,
Prof. Dr. Bryan Ford
(EPFL)

<https://eprint.iacr.org/2026/389>





Structure of Talk

Part I – Why Accountability is Needed

- Levels of Unlinkability
- Transferability Attacks
- Absolute vs. Conditional Privacy

Part II – The Cryptographic Forensic Trail (CFT)

- Design
- Usage
- Evaluation

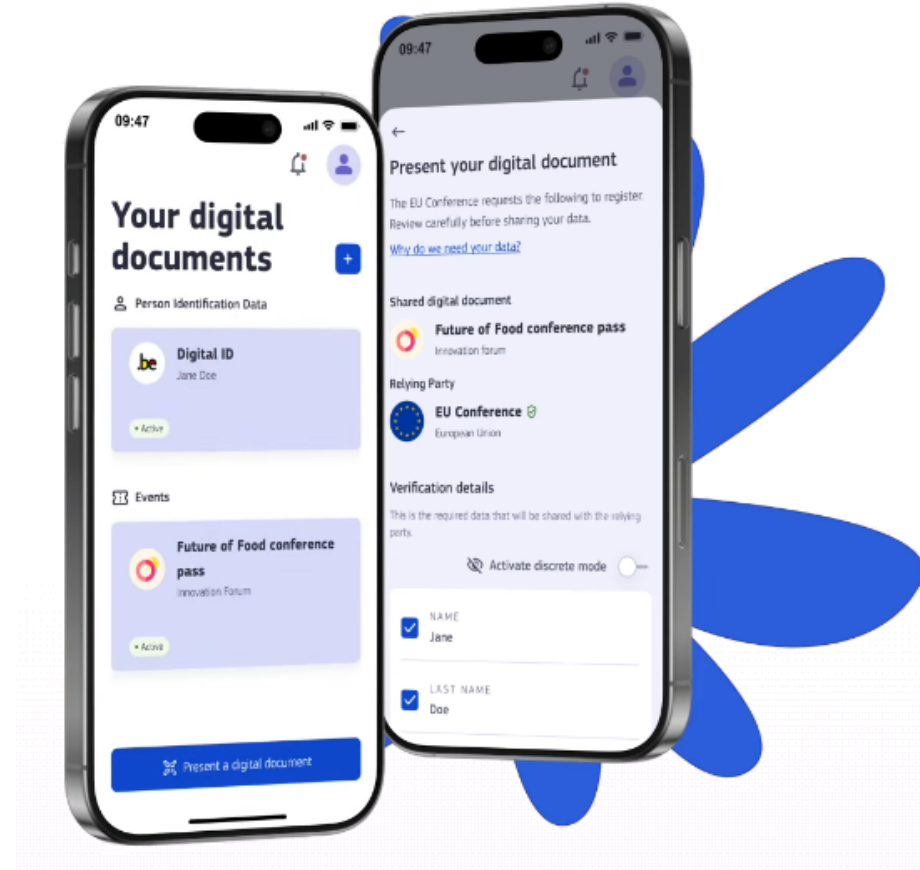
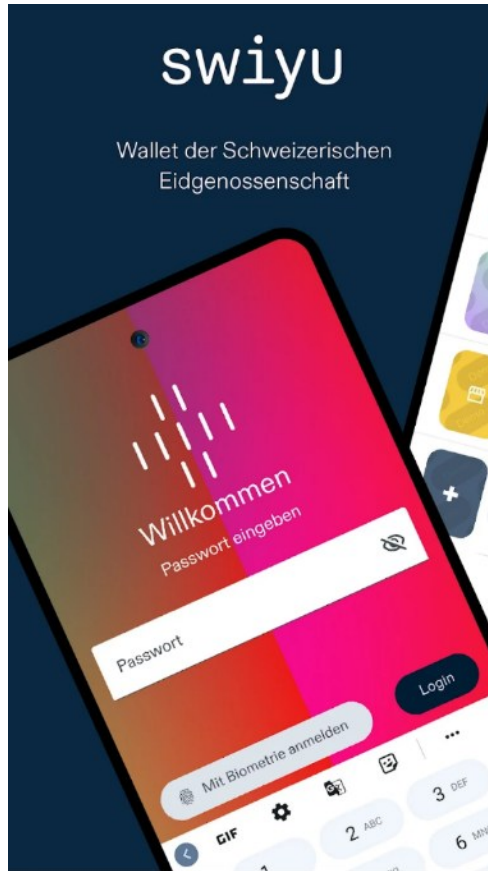


Part I

Why Accountability is Needed



EUDI Wallets and Swiss E-ID - Planned Go Live in 2026





Goal: Unlinkability of Presentations

✓ Gültig

Details

Foto



Amtlicher Name
Schweizer Sample

Vorname(n)
Helvetia

Geburtsdatum
01. 08.1995

Heimatort
Bern

Nationalität
Schweiz

Presented Content

- Swiss
- Older than 18

Technical Data (not directly visible)

- Issuer signature of VC
- Disclosures (salted/hashed claims)
- Public key of holders
- Revocation Information

Also, network metadata (e.g. IP address) could be used to correlate

Verifier



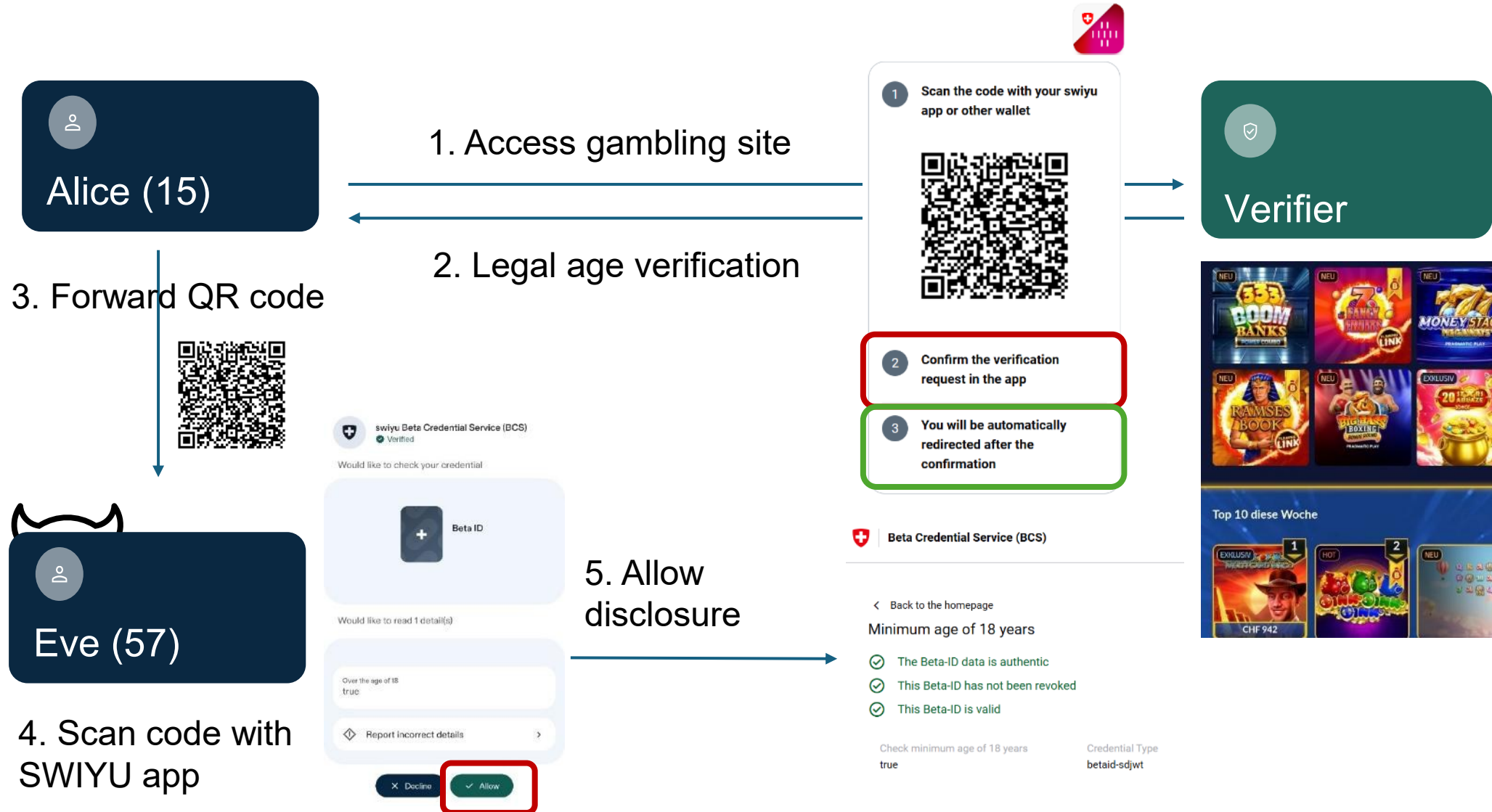
Levels of Unlinkability

Concept	Same Verifier	Cross-Verifier	Issuer-Verifier	Secure Enclave Support	Post-Quantum Secure	Comment
ECDSA + SD-JWT	X	X	X	OK	X	
BBS(+)	OK	OK	OK	X	X	
ECDSA + Batch-Issuance	OK	OK	X	OK	X	Used in Swiss e-ID
Pseudonyms	X	OK	OK	X/OK	X/OK	Used in EUDIW
Zero-Knowledge Proofs (ZKP)	OK	OK	OK	X/OK ^{*)}	X/OK	Practicality Issues, Active Research Area

^{*)}: Both possible, depending on variants. Secure enclave support/PQC typically comes with severe performance implications

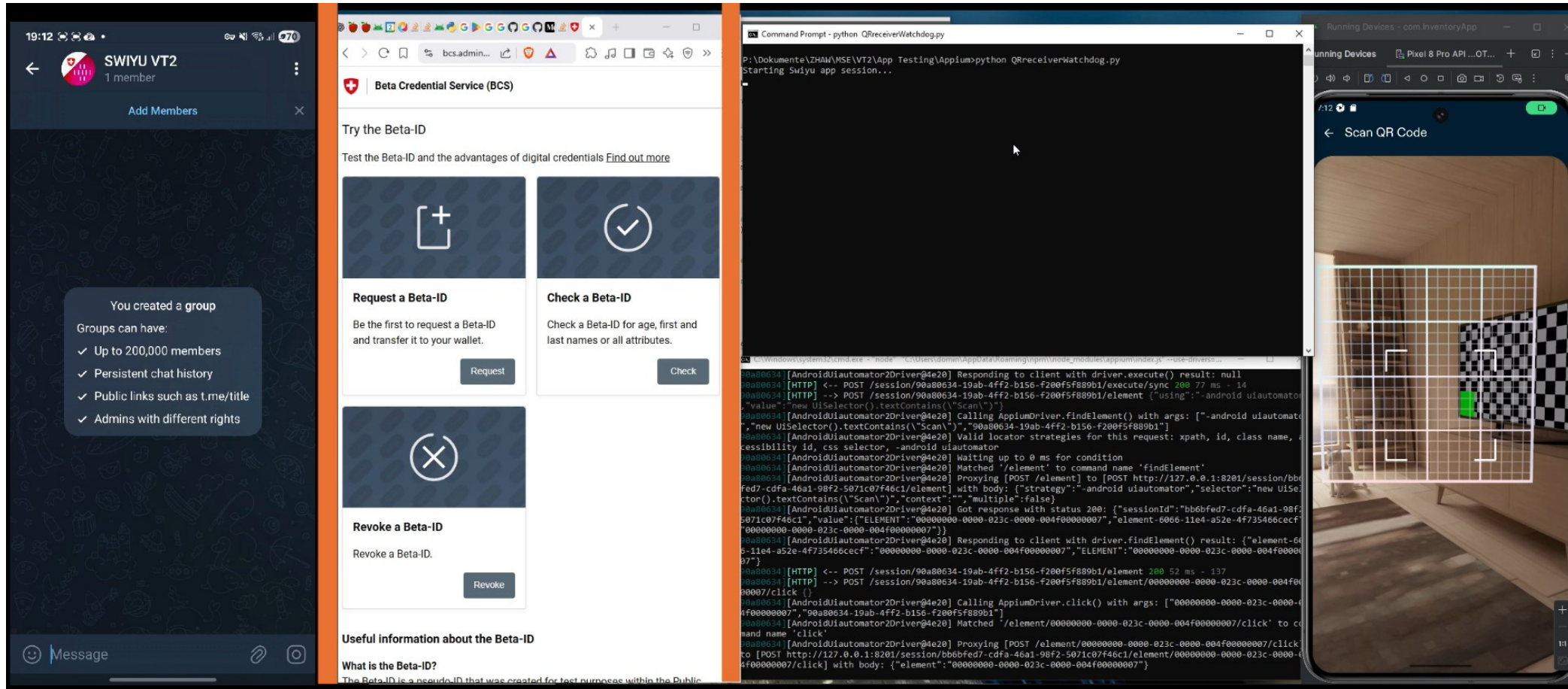
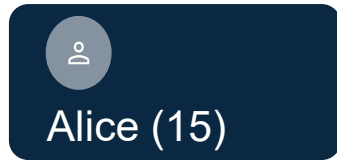


The Problem: Transferability of VC Presentations





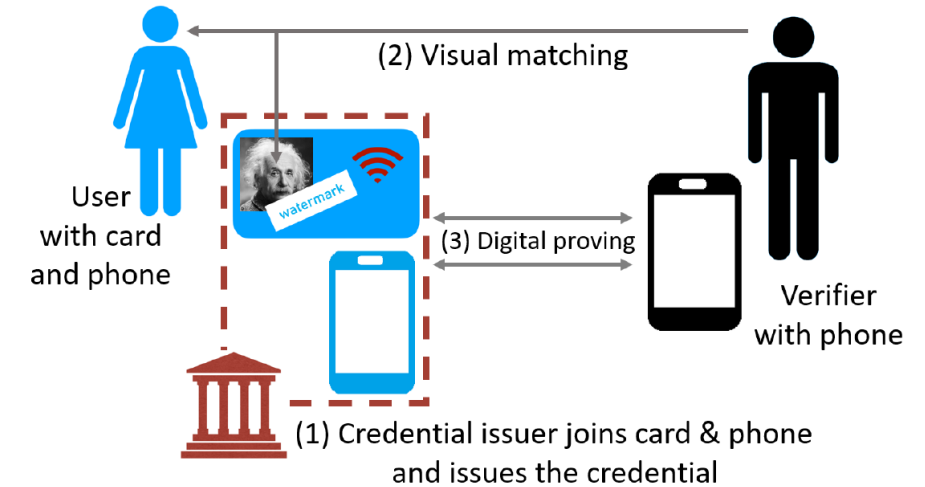
Automating Age Verification on Remote Phone





Root Cause: Holder Binding not Verified

Binding Element	On site (e.g. in a bar)	Online	Comment
Device Binding (private key stored in personal hardware device)	OK	OK	During credential issuance, hardware binding is verified using key attestation.
Biometric Picture stored in credential	OK	X	Verifying pictures online would require sharing biometric data and uploading selfies.



[1] Julia Hesse, Nitin Singh, and Alessandro Sorniotti. 2023. How to bind anonymous credentials to humans. In 32nd USENIX Security Symposium (USENIX Security 23)



Impact on Age Verification and Beyond

Age Verification: Open letter calls for moratorium [1]

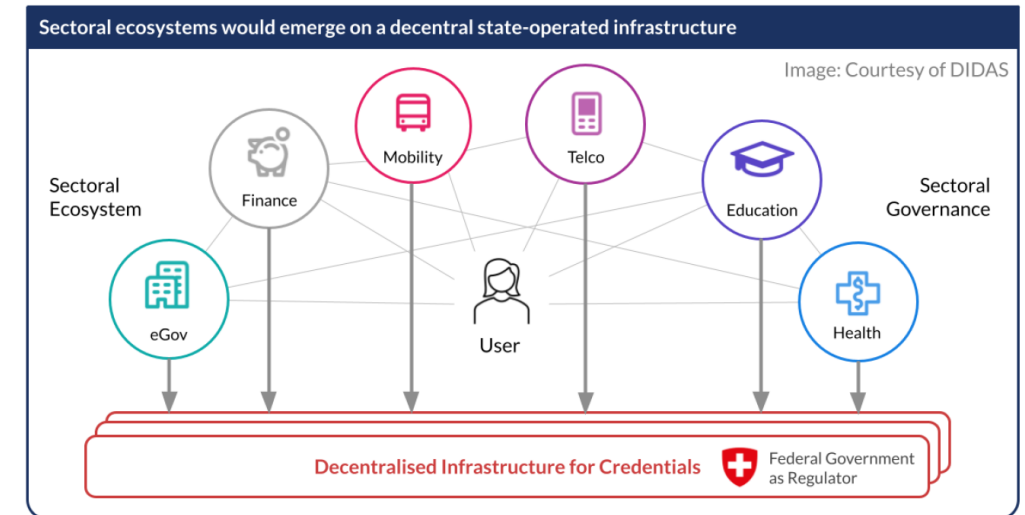
- Consensus on benefits/harms required
- Technical feasibility: «checks can be easily circumvented»

Not just e-ID, but an ecosystem of credentials

- Personhood
- Citizenship
- Health insurance coverage
- University degrees, etc.

Agentic AI [2]

- Special machine identities for agents?
- Transferability of human identities to agents?
- How to hold agents accountable?
- Prove personhood → Visibility and control gone!



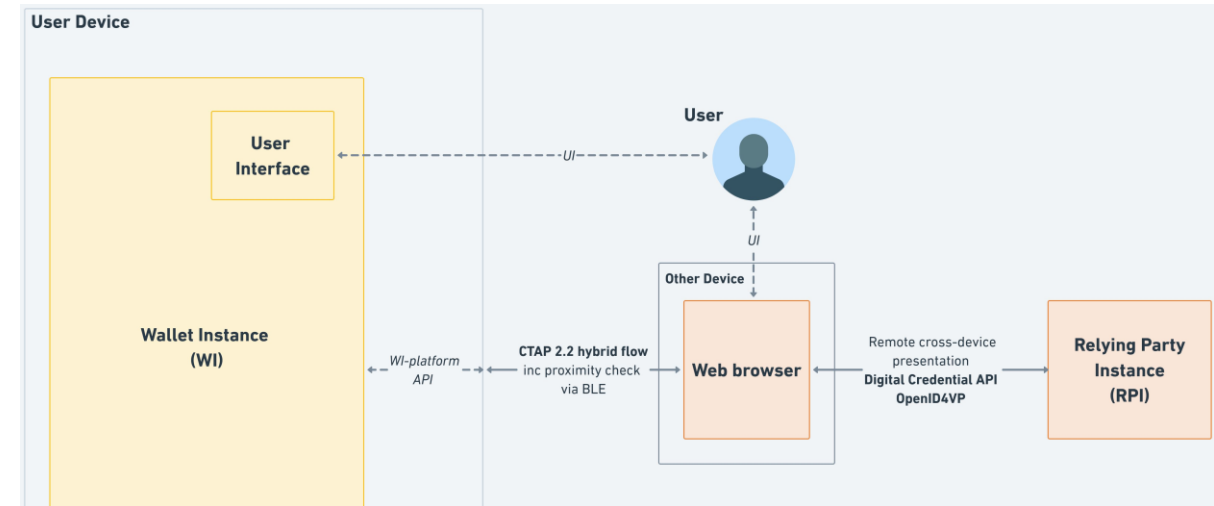
[1] René Mayrhofer, Bart Preneel, Diego Aranha, Olivier Blazy, Anja Lehmann, et al. 2026. Joint statement of security and privacy scientists and researchers on Age Assurance. <https://csa-scientist-open-letter.org/ageverif-Feb2026>

[2] Chan, A., Ezell, C., Kaufmann, M., Wei, K., Hammond, L., Bradley, H., et al. (2024, June). Visibility into AI agents. In Proceedings of the 2024 ACM conference on fairness, accountability, and transparency.



Bluetooth to the Rescue?

- OID4VP with Bluetooth proximity check (CTAP 2.2 hybrid flow) couples browser session with wallet on smartphone
- Great: Aims at raising bar for malicious users
 - Share browser/RP session with Eve
 - Tunnel Bluetooth link to Eve
- But:
 - Requires browser, wallet, and OS integration (alternative browser on Linux?)
 - If not mandatory (e.g. Swiss e-ID): Users chooses an incompatible setting
 - Only protects synchronous presentations. What if accounts are age-verified on stock and then sold?
 - Root cause (lacking holder binding) not addressed
 - BLE and security: it's complicated ;)



<https://eudi.dev/2.5.0/architecture-and-reference-framework-main/#4433-cross-device-remote-presentation-flows>



How will Governments Decide?

Unlinkability Concept	Accountability	Same Verifier	Cross- Verifier	Issuer- Verifier
ECDSA + Batch-Issuance	OK	OK	OK	X
ZKP	X	OK	OK	OK



Raise privacy for everyone



Give up ability to track down misuse



Absolute Privacy vs. Accountability

Conditional Privacy

Probable cause overrides privacy

Accountability

Honest users get full privacy

Separation of powers

Checks and balances

Democratic Societies



Absolute Privacy

«Diplomatic Immunity»

No accountability

Transferability attacks
successful

Governments call for backdoors

**Backdoors lower privacy
for ALL users**



If we want **strong privacy** to survive politically,
accountability is the price of admission.

... and cryptographers should design it before
politicians do.



Part II

Cryptographic Forensic Trail (CFT)



The Idea: Conditional Anonymity Revocation with Separation of Powers

In the physical world, searching a person requires:

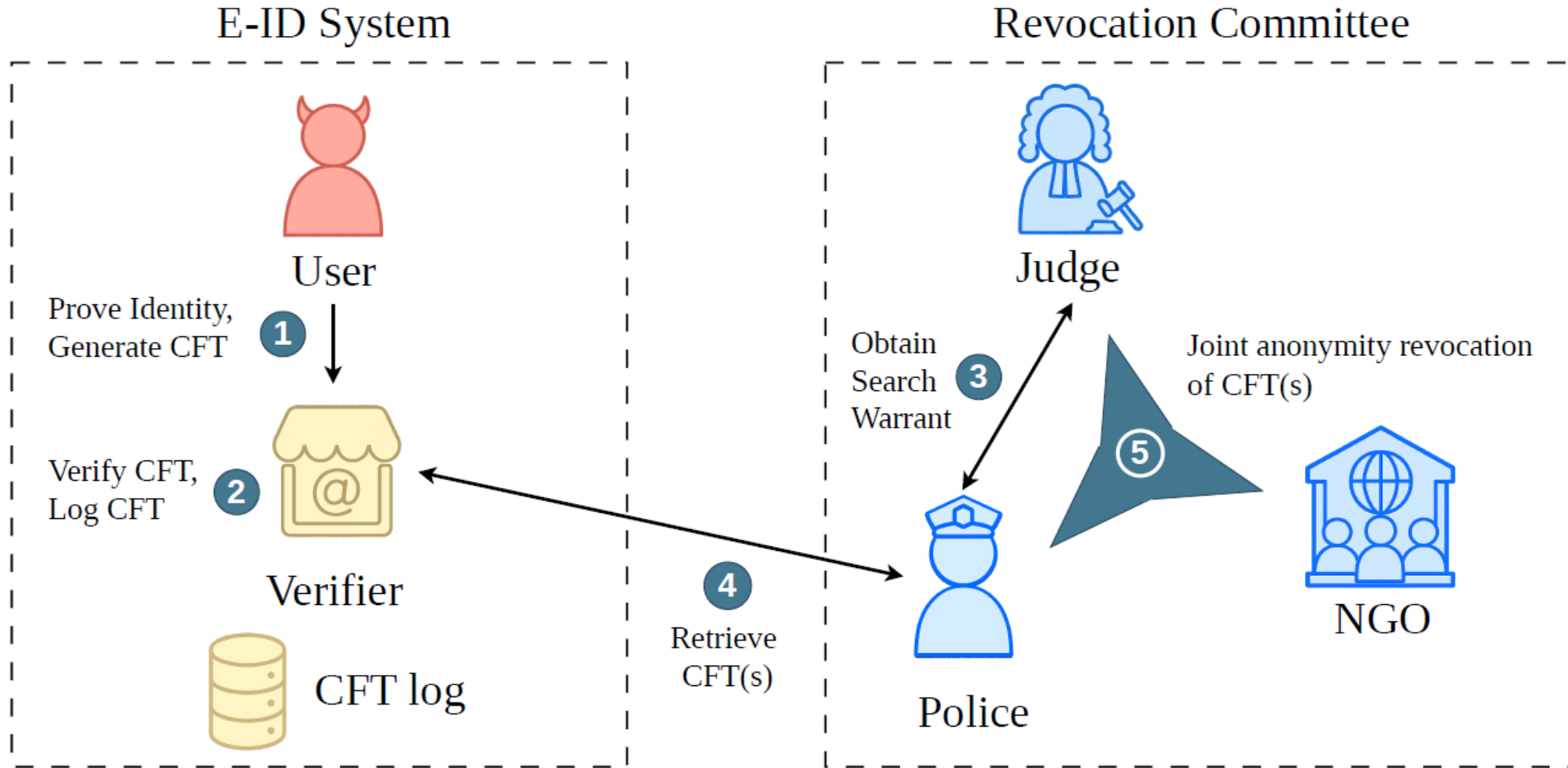
- **Police** with probable cause,
- A **judge** issuing a search warrant,
- Oversight by **civil society** to prevent abuse.

Role	Physical world	Digital system
Investigation	Police	Law enforcement body
Authorization	Judge	Judicial body
Watching the watchers	Press / NGOs	Digital rights NGO(s)

Checks and Balances,
enforced by cryptographic
protocols

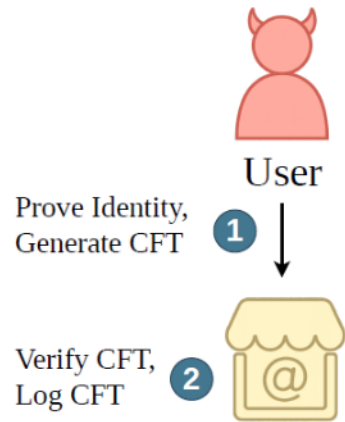


Cryptographic Forensic Trail (CFT) - Overview





CFT Under the Hood

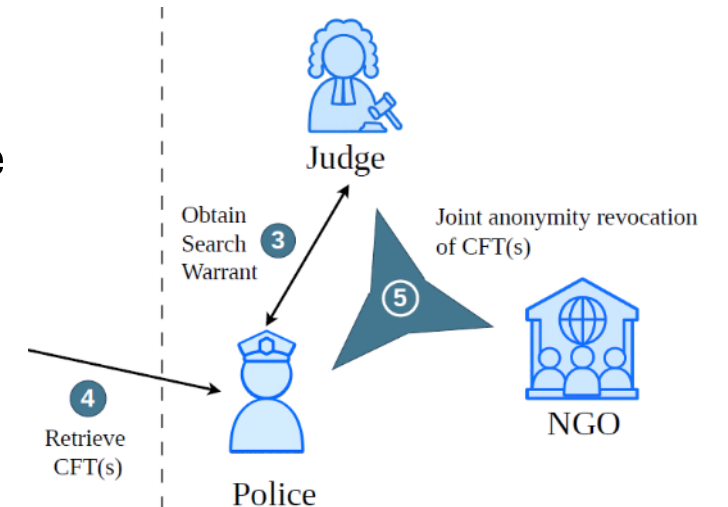


CFT generation

- $\text{CFT} = \text{Encryption}(\text{user ID}, \text{verifier ID}, \text{request ID}, \text{timestamp})$
- ElGamal: $\text{PK} = \text{PK}_{\text{police}} + \text{PK}_{\text{judge}} + \text{PK}_{\text{NGO}}$
- User generates ZKP for correct computation of CFT
- Verifier verifies ZKP and stores CFT

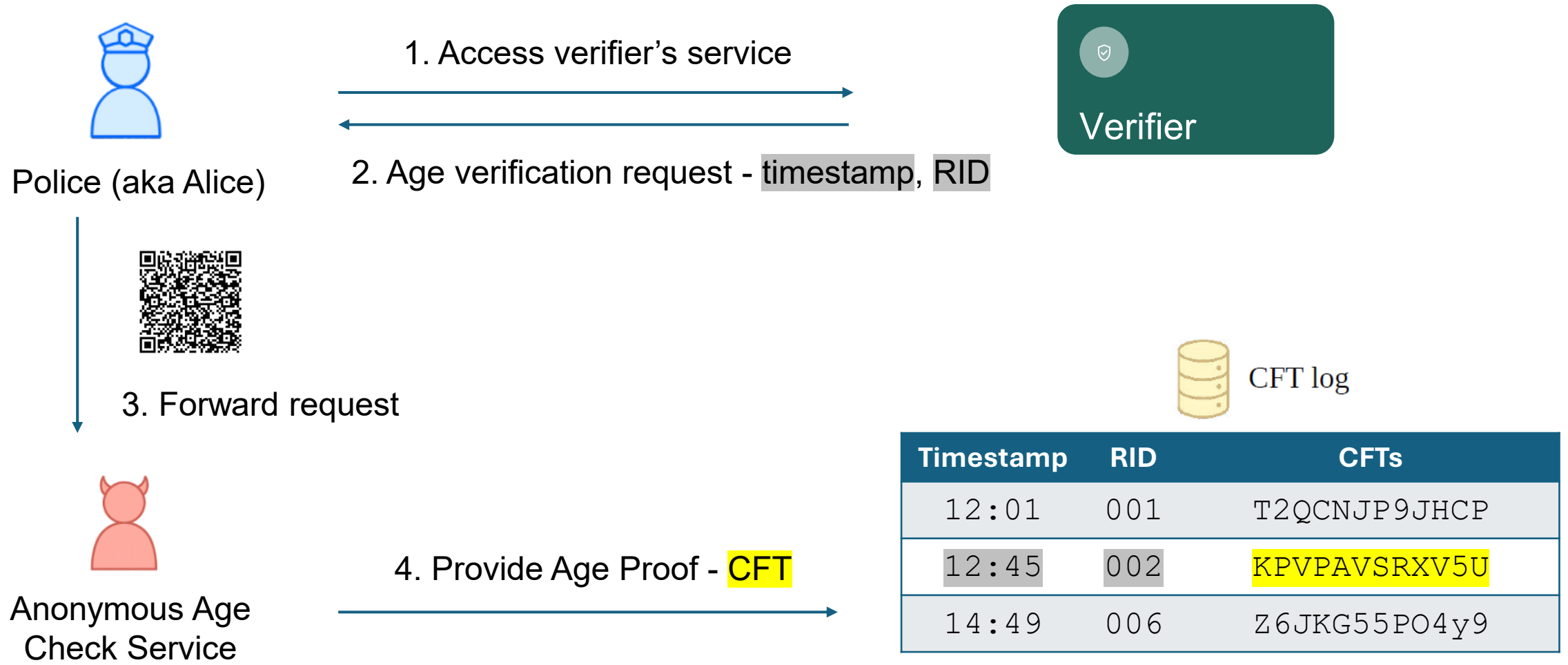
Anonymity Revocation

- **By Request ID** (single CFT): sequential decryption by committee
- **By Suspect ID or Behavioral Pattern** (set of candidate CFTs)
 1. Map CFTs to blinded identifiers
 2. Link suspect ID or pattern with blinded identifiers
 3. Decrypt matching CFT(s)





Search by Request ID





Search by ID and Behavioral Pattern - Naïve



CFT log

Timestamp	RID	CFTs (ElGamal, randomized)	Decrypted CFTs
12:01	001	T2QCNJP9JHCP	BOB
12:45	002	KPVPAVSRXV5U	EVE
13:02	003	3PUCR9W7QUNF	EVE
13:17	004	N4UY2EUMKW2M	BOB
14:22	005	YQN24EJLWTTY	ALICE
14:49	006	Z6JKG55PO4y9	BOB



Suspect ID = Eve

- Bob and Alice are innocent
- Their privacy was invaded!



Idea: Remove Unlinkability Before Decryption

ElGamal and (deterministic) Pohlig-Hellman encryption are **mutually commutative**

- Decryption/encryption keys can be applied in any order



Timestamp	RID	CFTs (ElGamal, randomized)
12:01	001	T2QCNJP9JHCP
12:45	002	KPVPAVSRXV5U
14:49	006	Z6JKG55PO4y9



Police

1. Decrypt with its ElGamal private key
2. Encrypt with (temporary) Pohlig-Hellman key

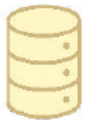


M2MN9N4Z7YHR

Blinded Identifier
(Pohlig-Hellman, deterministic)



Search by ID and Behavioral Pattern



CFT log



Remove Unlinkability

Timestamp	RID	CFTs (ElGamal, randomized)	Blinded Identifiers (Pohlig-Hellman, deterministic)
12:01	001	T2QCNJP9JHCP	M2MN9N4Z7YHR
12:45	002	KPVPAVSRXV5U	CEK75HFZ2MNP
13:02	003	3PUCR9W7QUNF	CEK75HFZ2MNP
13:17	004	N4UY2EUMKW2M	M2MN9N4Z7YHR
14:22	005	YQN24EJLWTTY	N5VLNH7W2KMU
14:49	006	Z6JKG55PO4y9	M2MN9N4Z7YHR



Suspect ID = Eve

PH («Eve») :

CEK75HFZ2MNP



Everyone with >2 requests
in 12:00-15:00



Performance of CFT Generation and Verification

Machine	Impl.	Prover [ms]		Verifier [ms]	
		No CFT	CFT	No CFT	CFT
Mobile	Standard	1424	1649 (+16%)	1197	1355 (+13%)
	zk-friendly	1676	1999 (+19%)	18	21 (+17%)
Server	Standard	1192	1441 (+21%)	854	1057 (+24%)
	zk-friendly	581	719 (+24%)	11	15 (+36%)

Overhead for prover on mobile phone below 20%

Mobile-like machine

- aarch64 machine
- 2 CPU cores, 4 GB of RAM

Server-like machine

- x86 64 machine
- 8 CPU cores, 16 GB of RAM

Standard: Longfellow-zk

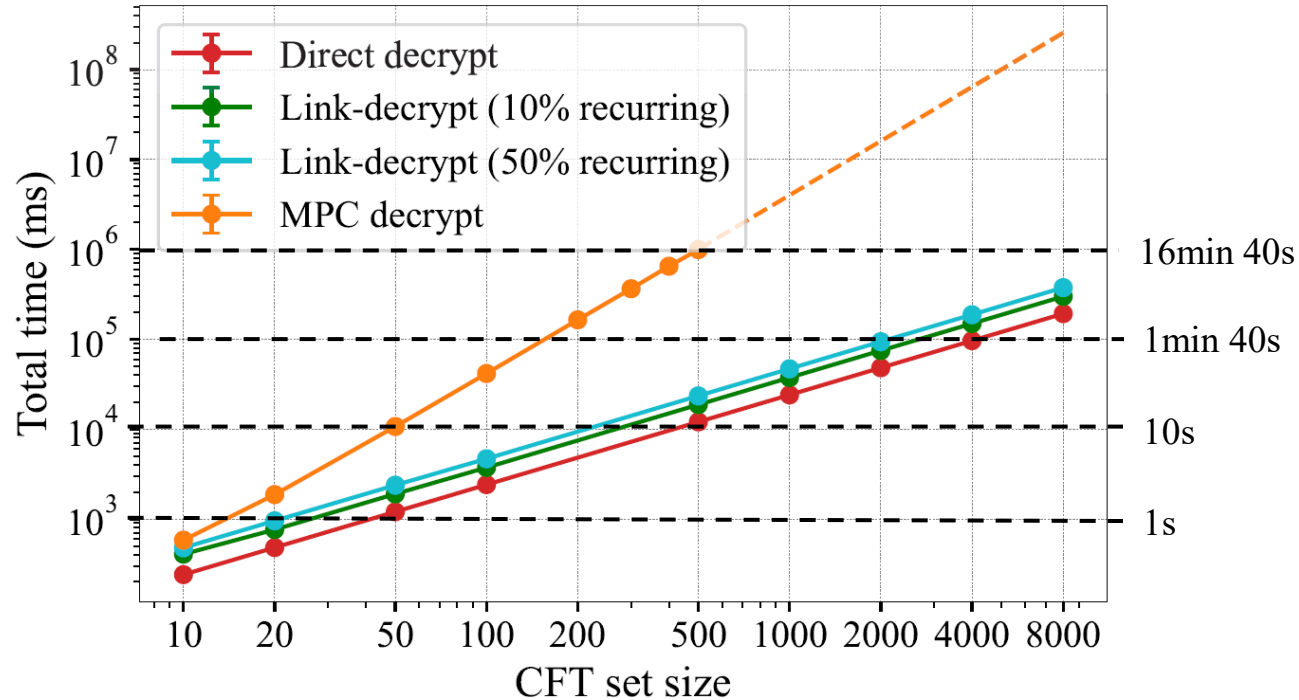
- P-256 curve, ECDSA, SHA-256
- Binding to secure enclave possible

ZK-friendly

- BabyJubjub curve, EdDSA, Poseidon
- Circom + Rapidsnark



Performance of Anonymity Revocation



Revocation times vs. CFT set sizes

Search by Request ID (Direct decrypt)

- 24 ms per revocation
- ~ 40 revocations/s

Search by Suspect ID / Behavioral Pattern (Link-decrypt)

- 35 ms for linking to blinded ID
- 24 ms per revocation
- ~16-28 revocations/s

MPC decrypt

- Hides access pattern of suspects
- Quadratical with CFT set size



Accountability Enables Privacy Improvement

Unlinkability Concept	Accountability	Same Verifier	Cross-Verifier	Issuer-Verifier
ECDSA + Batch-Issuance	OK	OK	OK	X
ZKP	X	OK	OK	OK
ZKP + CFT	OK	OK	OK	OK



WIN - WIN



Raise privacy for everyone



Keep ability to track down misuse



What We Need Next

Policymakers

- treat accountability as a privacy feature, not its opposite
- without built-in accountability, privacy loses politically

Standards bodies (EUDI ARF, Swiss e-ID)

- leave room for anonymity revocation in the architecture

NGOs / Civil society

- step up as the third pillar - independent, technical, trusted

Researchers

- prototypes, better multi-party protocols, post-quantum version



Schweizerische Eidgenossenschaft
Confédération suisse
Confederazione Svizzera
Confederaziun svizra

armasuisse
Science and technology

Thanks for your Attention

Dr. Martin Burkhardt
martin.burkhardt@ar.admin.ch
www.cyd-campus.ch

<https://eprint.iacr.org/2026/389>

